

100 Days of Azure DevOps

Day 64 Handout — Secrets, keys, certs — RBAC on the vault is the door; Contributor on the RG is not

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

Architecture A — three data types and two door locks

Thing	What it holds	Who reads it
Secret	Connection strings, dummy DemoSecret	Key Vault Secrets User (data plane). Not RG Contributor
Key	Cryptographic keys (encrypt/sign)	Key Vault Crypto User / Officer — different role
Certificate	TLS material, often with a key + secret projection	Cert roles; do not treat it as 'just a secret'
Access policies (legacy)	Vault-level policy entries per identity	Do not mix with RBAC on the same vault as a hobby
RBAC (modern)	--enable-rbac-authorization true. Data-plane roles on vault or secret	Control plane (vault resource) vs data plane (secret get) are different

Architecture B — decide dummy values, RBAC, and what not to screenshot

Constraint	Default	Reject
Authorization	RBAC vault. Secrets Officer to set, Secrets User to read	Access policies + RBAC both on, then debugging folklore
Value	DemoSecret = not-a-real-password	A real password in a learning vault you will photograph
Name	Globally unique vault name	Reusing a vault from a work sub
Soft delete	On by default. Literacy: recover deleted secrets	Purge in the lab just to feel thorough
Pipeline	Do not paste DemoSecret into YAML today	Day 65 fetches. Today the safe exists

Architecture C — pitfalls that leave the secret in git and the vault empty

Pitfall	What you see	Fix
Contributor, still 403	az keyvault secret show Forbidden	Assign Key Vault Secrets User / Officer on the vault ID
Secret in repo history	git log -p still has the password after you 'deleted the line'	Rotate. Treat history as leaked. Dummy values only today
Portal screenshot of the value	LinkedIn post is the incident	Show the name blade, not the value
Mixed permission model	Assignments you cannot reason about	RBAC only for this lab
Public network + real secret	Firewall later; dummy now	Do not put production secrets in a wide-open lab vault

One-liner to remember

Key Vault is the hotel safe — secrets in repo chat history are postcards from an incident. If git ever saw it, rotate; do not delete the line and call it done.

Step-by-step lab (personal Azure / Azure DevOps only)

Personal subscription rg-day64. Dummy value only. Personal UPN gets data-plane RBAC.

- 1 az group create -n rg-day64 -l eastus. az keyvault create -g rg-day64 -n <uniquekv> --enable-rbac-authorization true --sku standard.
- 2 Assign yourself Key Vault Secrets Officer on the vault resource ID (need set). Optional: also Secrets User if you want the read-only role in notes.
- 3 az keyvault secret set --vault-name <uniquekv> --name DemoSecret --value 'not-a-real-password'. az keyvault secret show --query name (not the value in any screenshot).
- 4 Confirm RG Contributor alone is not the story: the data-plane role is why show works. Write that sentence.
- 5 Do not enable access-policy mode. Do not put DemoSecret in the repo. Soft-delete literacy: note that delete is recoverable.
- 6 Write docs/kv-day64.md: vault name, RBAC vs access policies, Secrets User vs Officer vs Contributor. Pipeline integration is tomorrow.

Starter CLI + Bicep property — RBAC vault, dummy secret

```
az keyvault create -g rg-day64 -n <uniquekv> --enable-rbac-authorization true --sku standard
VAULT_ID=$(az keyvault show -n <uniquekv> --query id -o tsv)
az role assignment create --assignee <your-upn> --role "Key Vault Secrets Officer" --scope $VAULT_ID
az keyvault secret set --vault-name <uniquekv> --name DemoSecret --value "not-a-real-password"
az keyvault secret show --vault-name <uniquekv> --name DemoSecret --query "{n:name, id:id}" -o json
# Bicep: properties.enableRbacAuthorization: true
# Microsoft.KeyVault/vaults – control plane. Secret GET is data plane.
```

Done checklist

- RBAC vault exists; DemoSecret is a dummy
- Can explain why Contributor on the RG does not get secret GET
- No secret value in Git, chat, or LinkedIn
- docs/kv-day64.md records vault name and roles

Tomorrow — Day 65

Key Vault in pipelines — fetch at runtime, print length never the value